



NEED FOR API SECURITY



Need for API Security

Table of Contents

Need for API Security

Key Challenges	1
Limitations of WAF	5
Limitations of SAST	5
L7 Defence Ammune	6

Ammune Protection Modules

API WAF	8
API BOT	8
API DDOS	9
API BL	9
Ammune VS WAH	10



Need for API Security

API SECURITY – KEY CHALLENGES

APIs are building blocks for digital transformation. They have emerged as a critical means for exchanging data internally and externally through digital channels such as applications, cloud, and the Internet of Things (IoT), making it easy for enterprises to make their information available to wider audiences, whether they are customers, partners, employees, or applications.

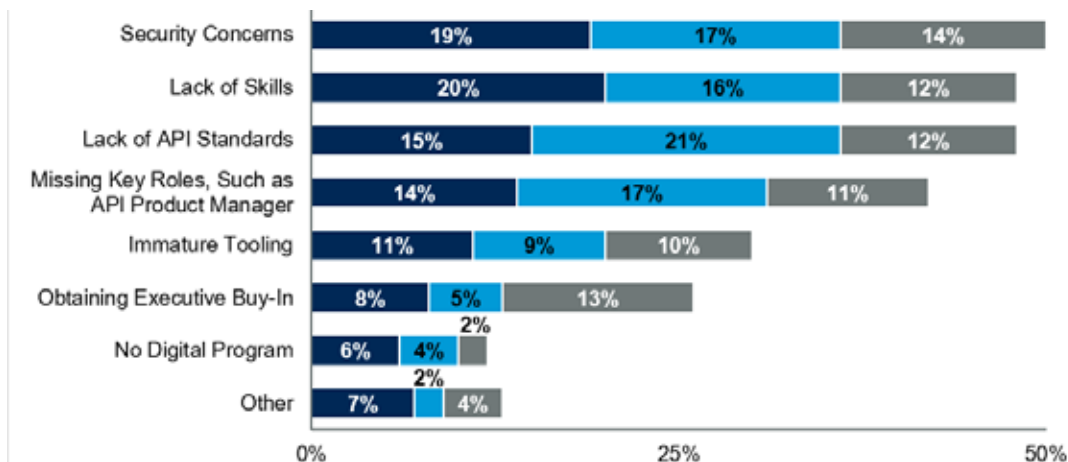
APIs expose data, services, and transactions—creating assets to be shared and reused with billions of API calls per day.

1. APIs can be easily hacked to gain access to core systems.

As per Gartner, 90% of web-enabled applications will have more attack surface area in exposed APIs rather than in the user interface making APIs the #1 Attack Vector.



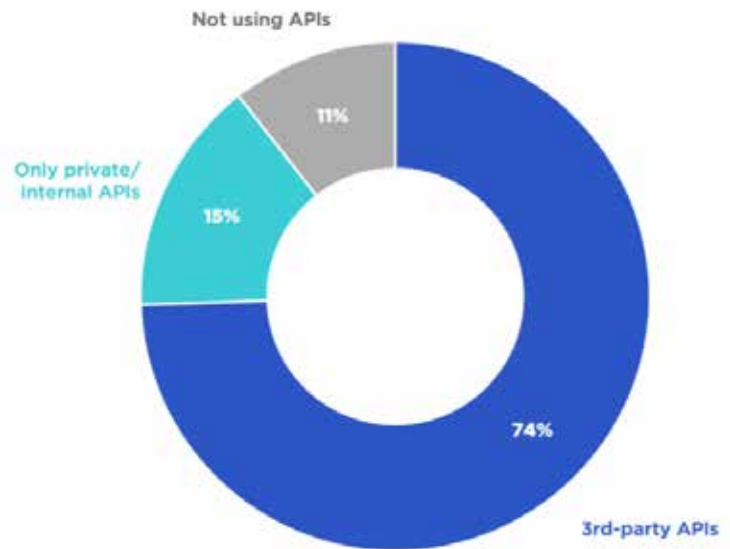
2. API Security remains a key challenge for API adoption.





Need for API Security

3. As per recent global survey, a greater number of organizations are leveraging 3rd party APIs to speed up the development efforts to meet deadlines.



/DATA State of the Developer Nation Q1 2023 | © SlashData | Some rights reserved

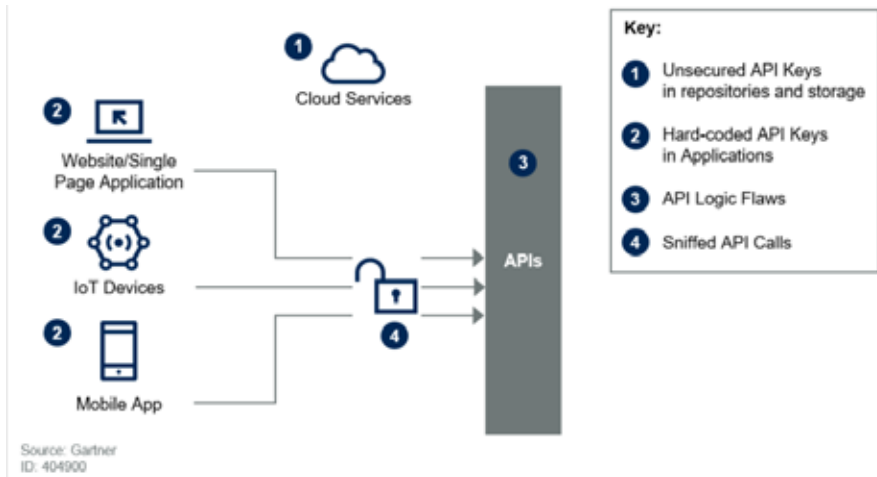
4. Managed vs Un-Managed APIs

- Large organizations have a complex ecosystem of legacy – of both managed and unmanaged APIs. Managed APIs are those whose lifecycle & security parameters may be controlled or better managed by Middleware tools like Enterprise Service Bus (ESB) or API Gateways.
- There is a large repository of REST & SOAP services or APIs (up to 80%) that have only basic authentication security. These types of APIs are susceptible to API attacks.



Need for API Security

5. Encrypted APIs can also be compromised. Encrypted APIs can be hacked by gaining access to the decrypted keys



- **Unsecured API keys and Encrypted keys in repositories and storage**

API keys or other keys, such as crypto keys, SSH keys, or SSL/TLS private keys, may be discovered or hacked.

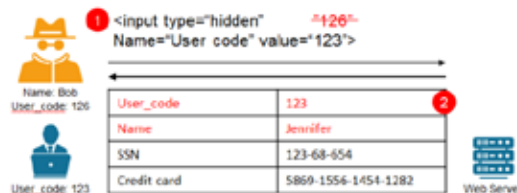
- **Hardcoded API keys in applications**

API keys or other credentials may be hardcoded in web and mobile applications. Also, mobile applications can be reverse-engineered to gain access to encrypted keys thus compromising API security.

Encrypted APIs can be hacked by exploiting Business Logic Flaws

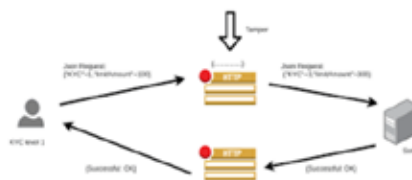
Business Logic attacks try to bypass the legitimate flows, functions, arguments, and structures

- API end-point **arguments** tampering
 - Wild argument value (*.*)
 - Out of range value
 - Mistype values (numeric vs text)
 - Unconventional input
 - Utilize other user identifiers (token, objects)



- API end-point **structural** tampering

- Missing arguments
- Additional arguments
- Disorder arguments





Need for API Security

- Transaction **flow** manipulation

- Skip step(s) in transaction processing
- Adding steps
- Tampering steps



Encrypted APIs can be compromised through Sniffing API Calls

- API traffic may be sniffed through a man-in-the-middle (MITM) approach, uncovering API keys or discovering unsecured APIs. For encrypted API's all the requests are encrypted end-to-end. It's impossible for the attacker to decrypt the message without a private key. However, there are many incidents in which hackers leverage MITM to compromise and gain access to private encrypted keys even though the API communication channel is secure through TLS

6. Threat from Shadow APIs

- Shadow APIs are unadvertised, no longer used, sample, or prototype APIs and are susceptible to API hacks

7. Threat from Zombie APIs

- Zombie APIs are deprecated APIs that everyone assumes have been disabled but actually exist and are easily susceptible to API hacks



Need for API Security

LIMITATIONS OF WEB APPLICATION FIREWALL (WAF)

Web Application Firewalls (WAFs) are proxy-based tools that inspect HTTP traffic to monitor, filter, and block malicious HTTP activity. These tools depend on signatures and are best used to prevent attacks exploiting known vulnerabilities.

WAF - Limitations

- WAFs can be Bypassed
- Does Not Protect Against Unknown/Zero-Day Exploits
- High Maintenance and Performance Overheads
- Lack of Support for API Ingress
- Lack of Support for Modern Tech Stack
- Lack of Support for complete OWASP API vulnerabilities
- Check Request Size Limitation



LIMITATIONS OF SAST, DAST & RASP TOOLS

Tools	Pros	Cons
SAST	• Analyzes complete codebase for security vulnerabilities • Done before the application is in production and without execution of the program • Points out the exact location of vulnerabilities and problem code	• Needs to synthesize data to test code leading to false positives • Not good at understanding libraries or frameworks, like API or REST endpoints • Unable to check calls or most argument values
DAST	• Evaluates whole application and system • Attempts to break encryption algorithms from outside • Tests for vulnerabilities in third-party interfaces	• Used after development is complete so fixing vulnerabilities is more expensive • Produces a large number of false positives
IAST	• Allows API testing , good for products using microservices • Combination of SAST and DAST functionality allows more accurate results and identification of a broader range of vulnerabilities	• Tools are proprietary, creating reliance on the supplier for support • Limited language support
RASP	• Runs continuous security checks and can respond to attacks with session termination or alerts • Not language or platform dependent • Highly dependent on language and framework versions	• Can only be used in production • Tempting to use as a fallback for catching vulnerabilities, leading to less rigorous pre-release testing



Need for API Security

NEED FOR API SECURITY – L7 DEFENSE AMMUNE™

Ammune™ API security solution by L7 Defense protects core systems from the most advanced, adaptive applicative attacks at very high precision, with minimal impact on normal operations. The solution operates as a 'plug and play' **autonomous** system, with a very low total cost of ownership (TCO).



Ammune™ utilizes advanced “**unsupervised AI learning**” technology for API defense. It automatically discovers and protects each API while iteratively learning the unique 'profile' of **every API** endpoint and dynamically correlates these insights to spot and stop emerging threats that would otherwise go unnoticed. Ammune™ does not require previous experience of a threat or its pattern of activity to identify such. It works automatically, without prior knowledge or signatures, detecting and fighting back against subtle, stealthy attacks in real time.

- **Simple deployment** – no agents, no proxy, no app changes, or performance impact
- **Automation** – establish baselines and adjust to changes with no tuning or configuration
- **Deep analysis** – correlate activity, find what's new, distinguish “bad” vs. “safe” difference
- **Enforcement** – tap the “low and slow” attack pattern to stop attackers before they succeed
- **Full lifecycle coverage** – protect and improve APIs across build, deploy, and runtime

Ammune™ protects from a wide range of cyber-attacks including variable attack forms that include changing the attacking vector(s), changing its amplitude, rotating the source IPs, etc.

- **Dynamic attack traffic rate** - Attack traffic may change from flood to regular or low rate
- **Fluctuating attack amplitude** - The attack amplitude may be stable or fluctuate over time
- **Irregular attack persistency** - The attack period may be short (seconds) medium (minutes, hours), or long (days to months)
- **Auto-adjust AI attacks** - The newest form of attack, in which it is optimized as a response to defense actions or detected “scanned” vulnerabilities. Here are two typical examples:
 - **Applicative AI-based DDoS attacks** that overcome static rate-dependent protections by dynamically adapting the distribution of attack traffic, to bypass the static rate limits
 - **Vulnerability scanners** that possess basic AI capabilities that optimize the scanning process according to target response



Need for API Security

Ammune™ leverages behavior-based protection, utilizing an autonomous unsupervised AI learning mode to perform continuous analysis of network traffic to discover API Endpoints along with sensitive data.

It implements a complete set of AI/ Machine Learning security models, to analyze the I/O traffic for each discovered API and to build its repository of behavior-based analytics.

A multi-service security model is implemented at each module to identify and protect from multi-API attacks

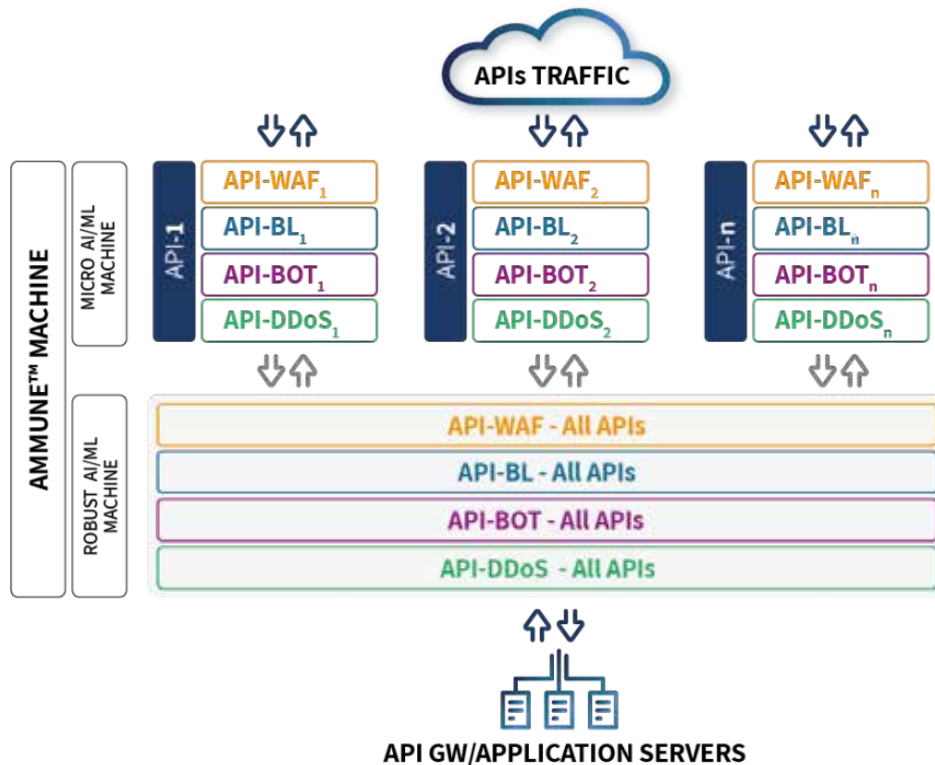


Figure - A schematic description of the Ammune™ protection model

Ammune™ is made to protect APIs from cyber-attacks and provides the following benefits.

- **Highly accurate, very low rate of False Positive errors** (user experience is undamaged) and very low rate of **False Negative** errors (every attack is being identified at high accuracy), while threat analysis and protection are conducted at **API resolution**.
- **Highly automated**, demanding only minimal human-based maintenance and support activities along its lifetime, dynamically and automatically changing its API-based protection policies according to monitored API changes.
- **Real-time**, providing an active, **inline protection**.
- **Continuously** adapting to changes in API and ever-changing attacks.



Need for API Security

AMMUNE PROTECTION MODULES

API-WAF MODULE

The API-WAF module protects from malicious content-based ("classical") applicative attacks, as appears in the 'OWASP top 10' - APIs and Applications security lists. Performing in real-time, it conducts full deep packet inspection (DPI), followed by an AI/ML analysis of requests and replies passing through, making it the ultimate first line of API protection.

"Top 10 Web Application Security Risks"

#	ATTACK TYPE
A-1	Injection
A-2	Broken Authentication
A-3	Sensitive Data Exposure
A-4	XML External Entities (XXE)
A-5	Broken Access Control
A-6	Security Misconfiguration
A-7	Cross-Site Scripting (XSS)
A-8	Insecure Deserialization
A-9	Using Components with Known Vulnerabilities
A-10	Insufficient Logging & Monitoring

"Top 10 API Security Risks"

#	ATTACK TYPE
A-1	Broken Object Level Authorization
A-2	Broken Authentication
A-3	Broken Object Property Level Authorization
A-4	Unrestricted Resource Consumption
A-5	Broken Function Level Authorization
A-6	Unrestricted Access to Sensitive Business Flows
A-7	Server Side Request Forgery
A-8	Security Misconfiguration
A-9	Improper Inventory Management
A-10	Unsafe Consumption of APIs

API-BOT MODULE

The API-BOT module protects APIs from business-related bot attacks, as listed in the 'Automated Threats to Web Applications' list, aka 'OWASP Top 20'. It performs real-time deep packet inspection (DPI), followed by near real-time AI/ML analysis of the API(s) traffic, content, context, and metadata, using specific bot activity measurements made according to bot type activity characteristics.

"Automated Threats to Web Applications" (OWASP Top 20)

#	ATTACK TYPE
OAT-1	Carding
OAT-2	Token Cracking
OAT-3	Ad Fraud
OAT-4	Fingerprinting
OAT-5	Scalping
OAT-5	Expediting
OAT-6	Credential Cracking
OAT-6	Credential Stuffing
OAT-7	CAPTCHA Defeat
OAT-8	Card Cracking
OAT-10	Carding

#	ATTACK TYPE
OAT-11	Scraping
OAT-12	Cashing Out
OAT-13	Sniping
OAT-14	Vulnerability Scanning
OAT-16	Denial of Service
OAT-17	Skewing
OAT-18	Spamming
OAT-19	Footprinting
OAT-19	Account Creation
OAT-20	Account Aggregation



Need for API Security

API-DDOS MODULE

The API-DDoS module protects from DDoS attacks tailored against specific API(s). This attack may use camouflage techniques, such as rotating source IPs, and request content randomization, while using optimization algorithms to decide on the next wave of attack. Ammune™ API-DDoS module performs real-time deep packet inspection (DPI), followed by AI/ML analysis of the API(s) traffic to find exceptional API(s) related resources consumption at a time scale of seconds.

Top API-DDoS Attack Methods (HTTP/s)

#	ATTACK TYPE	#	ATTACK TYPE
L7D-1	Classical botnets flood attack	L7D-11	Hit & run / randomly changing traffic volumes attack
L7D-2	Human mimicking attack	L7D-12	Baseline poisoning attack
L7D-3	AI-based optimization attack	L7D-13	Flash crowding mimicking event attack
L7D-4	Heavy file downloads attack	L7D-14	Attack occurs through flash crowding event
L7D-5	Rotating IP's attack	L7D-15	Asymmetric requests attack
L7D-6	IoT source IP's / anonymous proxies attacks	L7D-16	Brute force attack
L7D-7	Multiple vectors attacking simultaneously	L7D-17	SlowLoris and slow-post attack
L7D-8	Request content randomization attack	L7D-18	Slow read attack
L7D-9	"Out of scheme" parameters and contents attack	L7D-19	SSL re-negotiation attack
L7D-10	Cache evading attack	L7D-20	SSL session exhaustion attack

API-BUSINESS LOGIC (BL) MODULE

The API-BL module protects APIs from Business Logic (BL) attacks, that lead to forbidden data or functionality access or abused business processes and fraud. We partially listed these attacks in the 'OWASP Top 10 - API security list', while a few more attack types were added. Ammune™ performs in-session traffic analysis to identify these attack patterns in real-time, involving session as well as historical data points. It completes the first line of protection together with the API-WAF module.

"Top 10 API Security Risks"

#	ATTACK TYPE
API-1	2019 Broken Object Level Authorization
API-2	2019 Broken User Authentication
API-3	2019 Excessive Data Exposure
API-4	2019 Lack of Resources & Rate Limiting
API-5	2019 Broken Function Level Authorization
API-6	2019 Mass Assignment
API-7	2019 Security Misconfiguration
API-8	2019 Injection
API-9	2019 Improper Assets Management
API-10	2019 Insufficient Logging & Monitoring

More API-based BL attacks

#	ATTACK TYPE
L7B-1	Broken payment flow - missing bind between payment and order
L7B-2	Broken payment flow
L7B-3	Broken credentials restore flow
L7B-4	Broken credentials revoke flow
L7B-5	JWT Token tampering
L7B-6	Insufficient 3rd party application trust



Need for API Security

L7DEFENSE AMMUNE VS WAF

SN. No	Issue	Ammune™ Fully Automated Features	WAF Relevant Features
1	Prevent classical content-based API attacks	- Positive and negative models are made at request argument data - The negative model uses an NLP based risk analysis approach aimed to find specific attack types - The positive ML model detects general anomalies - Correlation of results is a highly reliable process that can detect buffer overflow attacks, early probing attempts, and highly embedded threats using evading techniques	- Signature-based discovery that is sensitive to evading techniques - Swagger schema enforcement and Protocol Conformance - mostly inefficient in such cases as they don't limit the content - Doesn't stop attackers in the early reconnaissance/probing stage
2	Prevent API abuses by users	Context-based ML analysis at transaction and anomaly sequences grouped by entity lead to a fine-tuned, highly sensitive detection process that can find abnormal usage patterns of specific API endpoint at a session level	Swagger schema enforcement which is not relevant to most such attacks
3	Prevent API abuses by bots	- Bot analysis uses a learned blueprint of the API to search for certain repetitive activity patterns at entity and API endpoint level that are aimed to abuse - Intent-based analysis allows capturing low and slow bot attacks	Anti-bot- signatures and client-side protection, which are both easy to bypass and not efficient in B2B/M2M API
4	Enable API governance	- Automatically and continuously discovers active API endpoints, highlighting changes in the API interface and detect APIs that expose private data - Enables to proactively detect and protect shadow APIs	Discovers API endpoints without information regarding arguments and API changes



Need for API Security

As per the test conducted in a leading bank, it was found that WAFs are capable of identifying and mitigating around 30% of threats, allowing the rest to seep into the application layer.

	Traditional WAF	ammune.ai	
24h Logging			
Alerts	234	1543	+ 659%
Security issues	22	156	+ 709%

Figure - Recent Benchmark at a Tier-1 (EU) Bank



Need for API Security

AMMUNE.AI MITIGATES OWASP 2023 VULNERABILITIES

SN. No		Overview	How Ammune™ helps
1	API #1: Broken Object Level Authorization	BOLA-vulnerable APIs can allow adversaries to access unauthorized data. This can be executed by manipulating a legitimate API request so that the target API returns data that the requester should not have authorization to access.	- Advanced machine learning (ML) and Artificial Intelligence (AI) build baseline API behaviors so that BOLA attack traffic can be detected - Detecting and highlighting sensitive data on API Discovery view will help the security team in early discovery of potential threats and vulnerabilities - As part of API profile learning, the system automatically identifies association rules—persistent dependencies between token/user properties and response data for each API endpoint. During a BOLA exploit, a user gains access to data belonging to other users, violating these association rules. Ammune will detect this breach and send a notification. - Automatically discover object_id and set security controls to prevent highly anomalous aggregation of different object_id in a single entity flow (IP, user, etc) Ammune™ -BOT: - Detecting and blocking bots that try to access privileged API methods
2	API #2: Broken Authentication	Authentication controls are weak or easily defeated, allowing attackers to gain complete control of other users' accounts in the system, read their personal data, and perform sensitive actions on their behalf.	- API Discovery module coupled with Advanced Machine Learning (ML) and Artificial Intelligence (AI) build baseline API behavior including structure of API and sensitive data, so that Broken Authentication attack traffic can be detected - Detecting and highlighting sensitive data using API Discovery module and tagging sensitive data enables the security team to proactively detect problems - Runtime protection detects and blocks credential stuffing and brute force attacks
2	API #3: Broken Object Property Level Authorization	This is a combination of excessive data exposure and mass assignment Unauthorized access to private/sensitive object properties may result in data disclosure, data loss,	- API Discovery module coupled with Advanced Machine Learning (ML) and Artificial Intelligence (AI) build baseline API behavior including the structure of API and sensitive data and API methods so that Broken Object property level Authorization attack traffic can be detected - Detecting and highlighting sensitive data on the API Discovery view will help the security team in the early discovery of potential threats and vulnerabilities - Runtime protection detects and blocks abnormal



Need for API Security

SN. No		Overview	How Ammune™ helps
		or data corruption leading to privilege escalation or account takeover.	amounts of sensitive data consumed by IP/user triggered by data scraping attacks - Runtime protection detects and blocks enumeration bots (abusing insecure direct object reference vulnerability via enumerating object_ids in URL or body) - Runtime protection detects and blocks anomalies that involve abnormal structure of the JWT as per API endpoint and/or missing 'must-have' access token. As such anomalies could be a result of version change – Ammune uses correlation analysis on user and IP levels to decide whether the anomaly is an attack or not - Runtime protection detects and blocks attackers that enumerate URL/methods to find hidden API endpoints. Ammune™ -BL: - Ammune™ collects all request and response anomalies (including more subtle ones that are not blocked by Ammune API-WAF) and assesses each user, IP, and token to determine whether it is a malicious reconnaissance/exploit flow. Ammune™ -BOT: - Detecting and blocking bots that try to access privileged API methods
4	API #4: Unrestricted Resource Consumption	Exploitation can lead to a Denial of Service attack due to resource starvation causing API to become unresponsive. It can also lead to higher operational costs increase such as those related to the infrastructure due to higher CPU demand, increasing cloud storage needs, etc.	- API Discovery module coupled with Advanced Machine Learning (ML) and Artificial Intelligence (AI) build baseline API behavior including structure of API and sensitive data and API methods - Detecting and highlighting sensitive data on API Discovery view will help the security team in the early discovery of potential threats and vulnerabilities - Runtime protection detects anomalous traffic surges - Ammune™ DDoS module automatically detects API endpoints that are sensitive to DOS and DDoS including low and slow DDoS attacks and automatically generate throttling rules on user and/or IP levels



Need for API Security

SN. No		Overview	How Ammune™ helps
5	API #5: Broken Function Level Authorization	Inadequate or poorly configured APIs allow access to additional functions such as HTTP methods (e.g. POST, DELETE) Such flaws allow attackers to access unauthorized functionality. Administrative functions are key targets for this type of attack and may lead to data disclosure, data loss, or data corruption. Ultimately, it may lead to service disruption.	• API Discovery module coupled with Advanced Machine Learning (ML) and Artificial Intelligence (AI) build baseline API behavior including structure of API and sensitive data and API methods • API Discovery analysis flags APIs with privileged API methods and public exposure • Runtime protection detects and prevents fraudulent API requests such as admin methods or privileged API calls. Ammune™ -BOT: • Detecting and blocking bots that try to access privileged API methods Ammune™ - BL: • Ammune™ collects all request and response anomalies (including more subtle ones that are not blocked by Ammune API-WAF) and assesses each user, IP, and token to determine whether it is a malicious reconnaissance/exploit flow.
6	API #6: Unrestricted Access to Sensitive Business Flows	APIs vulnerable to this risk expose a business flow such as buying a service/product or posting a comment that may be exploited in an adverse way to harm the enterprise if used excessively in an automated manner.	• API Discovery module coupled with Advanced Machine Learning (ML) and Artificial Intelligence (AI) build baseline API behavior including structure of API, sensitive data, and critical business flows • API Discovery analysis flags APIs with sensitive business flows • API real-time WAF protects sensitive business flows from advanced threats and vulnerabilities ammune™ -BL: ● Ammune™ collects all request and response anomalies (including more subtle ones that are not blocked by Ammune API-WAF) and assesses each user, IP, and token to determine whether it is a malicious reconnaissance/exploit flow.
7	API #7: Server-side Request Forgery	Successful exploitation might lead to internal services enumeration (e.g. port scanning), information disclosure, bypassing firewalls, or other security mechanisms. In some cases, it can lead to DoS or the server being used as a proxy to hide malicious activities.	• API Discovery module coupled with Advanced Machine Learning (ML) and Artificial Intelligence (AI) build baseline API behavior including structure of API, sensitive data, and critical business flows • Security model based on NLP – checks for each attribute against server-side forgery and block attacks in real-time • Ammune™ DDoS module automatically detects API endpoints that are sensitive to DOS and DDoS including low and slow DDoS attacks and automatically generate throttling rules on user and/or IP levels



Need for API Security

SN. No		Overview	How Ammune™ helps
8	API #8: Security Misconfiguration	Security misconfigurations not only expose sensitive user data but also system details that can lead to full server compromise	• API Discovery module coupled with Advanced Machine Learning (ML) and Artificial Intelligence (AI) build baseline API behavior including structure of API, sensitive data, and critical business flows • Security model based on NLP – checks for each attribute against server-side forgery and block attacks in real-time • API real-time WAF protects sensitive business flows from advanced threats and vulnerabilities Ammune™ -BL: • Ammune™ collects all request and response anomalies (including more subtle ones that are not blocked by Ammune API-WAF) and assesses each user, IP, and token to determine whether it is a malicious reconnaissance/exploit flow.
9	API #9: Improper Inventory Management	Attackers can gain access to sensitive data, or even take over the server. Sometimes different API versions/deployments are connected to the same database with real data. Threat agents may exploit deprecated endpoints available in old API versions to get access to administrative functions or exploit known vulnerabilities.	• API Discovery module coupled with Advanced Machine Learning (ML) and Artificial Intelligence (AI) build baseline API behavior including structure of API, sensitive data, and critical business flows • API real-time WAF protects sensitive business flows from advanced threats and vulnerabilities Ammune™ -BL: • Ammune™ collects all request and response anomalies (including more subtle ones that are not blocked by Ammune API-WAF) and assesses each user, IP, and token to determine whether it is a malicious reconnaissance/exploit flow.
10	API #10: Unsafe Consumption of API	This attack can leverage malicious traffic to cause serious performance issues. Successful exploitation may lead to sensitive information exposure, injection-based attacks, and denial of service.	• API Discovery module coupled with Advanced Machine Learning (ML) and Artificial Intelligence (AI) build baseline API behavior including structure of API, sensitive data, and critical business flows • API real-time WAF protects sensitive business flows from advanced threats and vulnerabilities • Automatically detects API endpoints that are sensitive to DOS and DDoS and automatically generates throttling rules on user and/or IP levels



Need for API Security

Conclusion:

APIs are the building blocks of digital transformation and are key to creating today's immersive user experiences. What the future holds for them is yet unknown, but you can bet that they'll further enhance and propel new services and experiences that power digital economies. APIs carry business logic and data and hence its of paramount importance that the API Security solutions work in an air-gapped environment. This is to ensure that security threats of today and tomorrow cannot slow down innovation.

To find out more about creating immunity to API-borne threats with leading-edge AI-based defense, click to visit www.ammune.ai